

Email Header Analysis

Overview

This guide provides a systematic approach to analyzing email headers for cybersecurity investigations. You will learn to identify legitimate versus suspicious emails by examining metadata, authentication mechanisms, and common attack patterns.

Lab Setup

Required Software

1. Email Client: Thunderbird

Download from: [Thunderbird](#)

Installed Windows machines for viewing .eml files

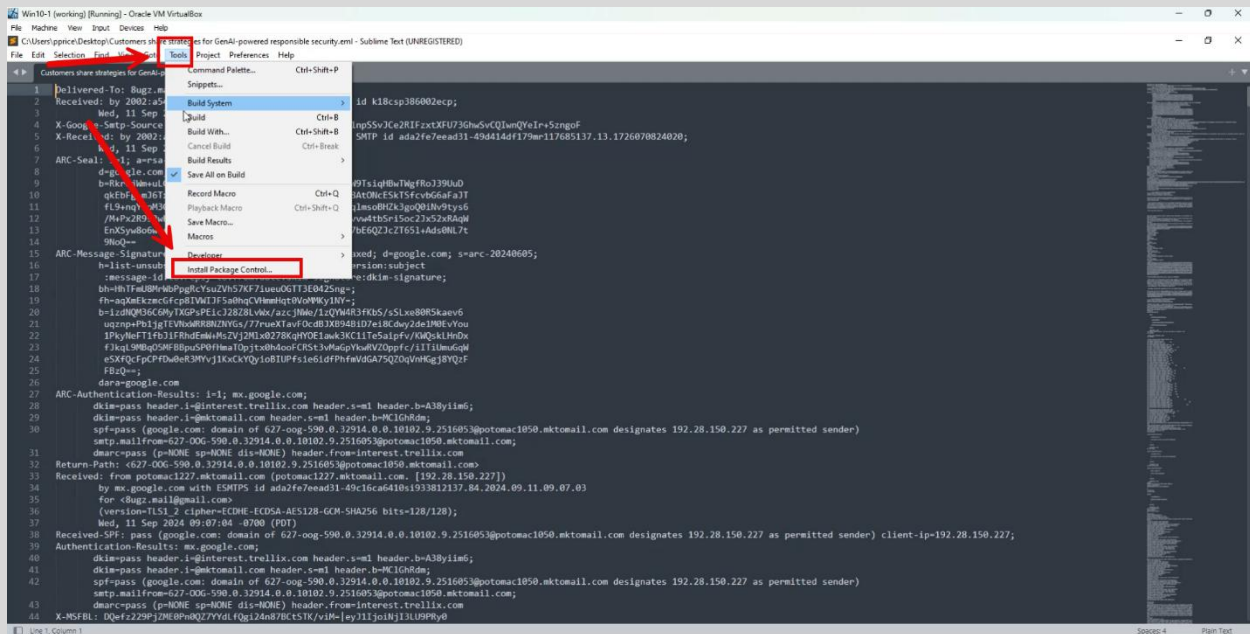
2. Text Editor: Sublime Text

Download from: [Sublime Text](#)

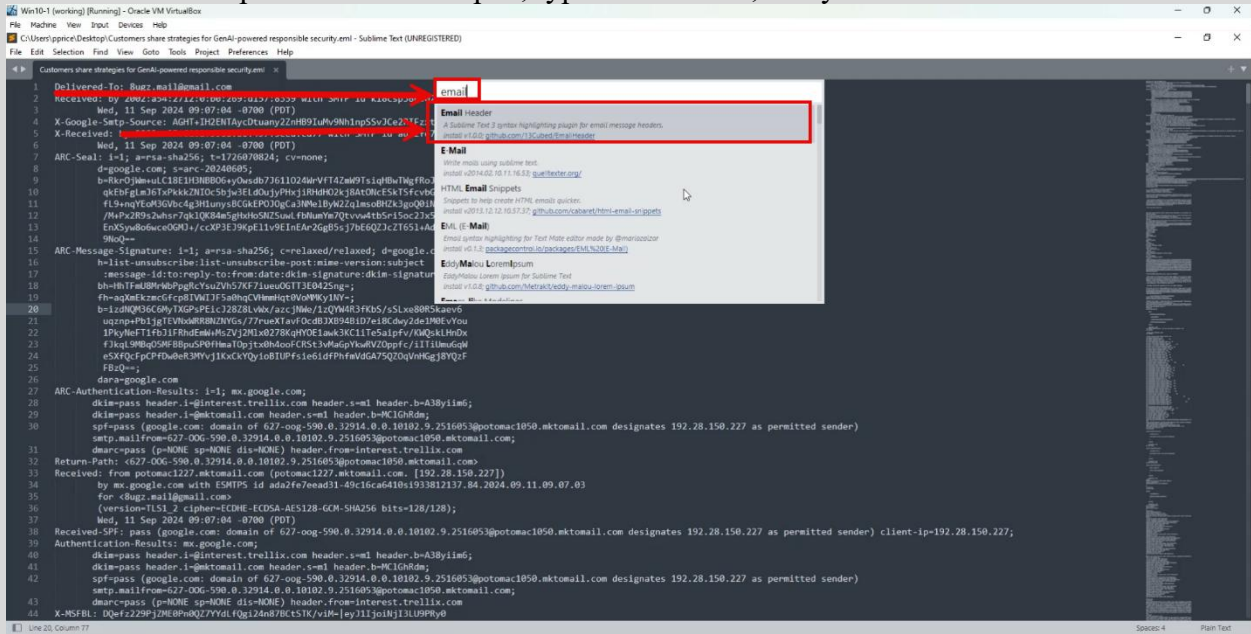
Used for detailed header analysis with syntax highlighting

Installing Email Header Plugin for Sublime Text

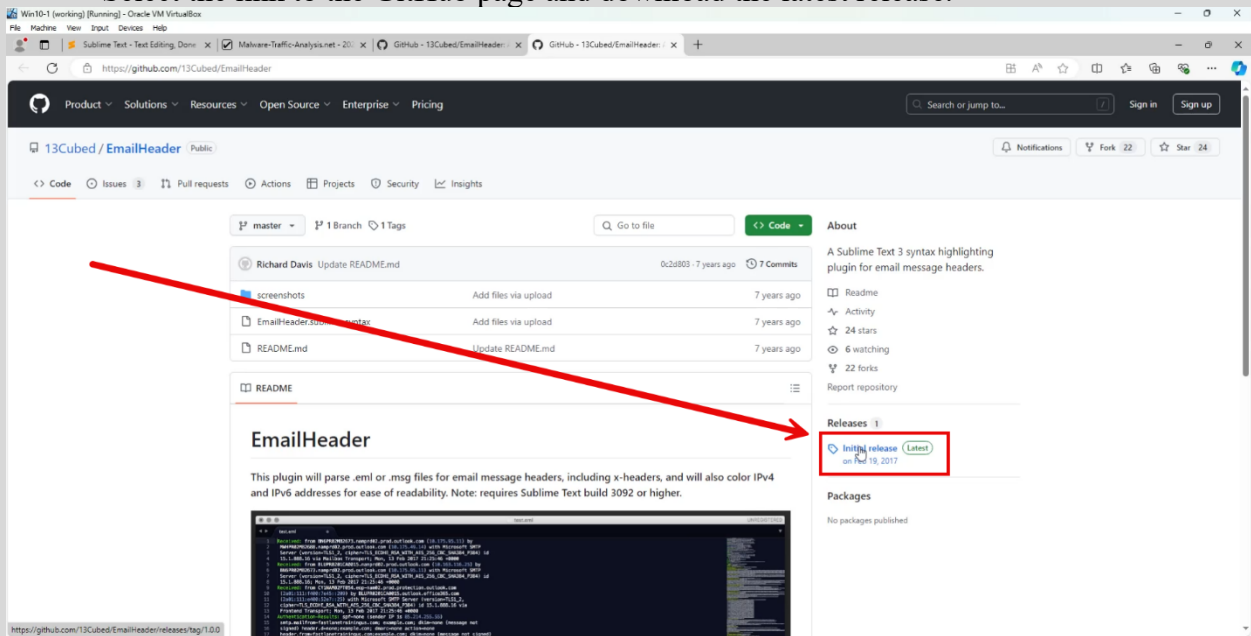
- Open Sublime Text Editor and go to Tools and then drop down to Install Package Control. Press “Control-Shift-P,” and when the input window opens, start typing “install”; you will see the option to select Package Control: Install Package. Select it



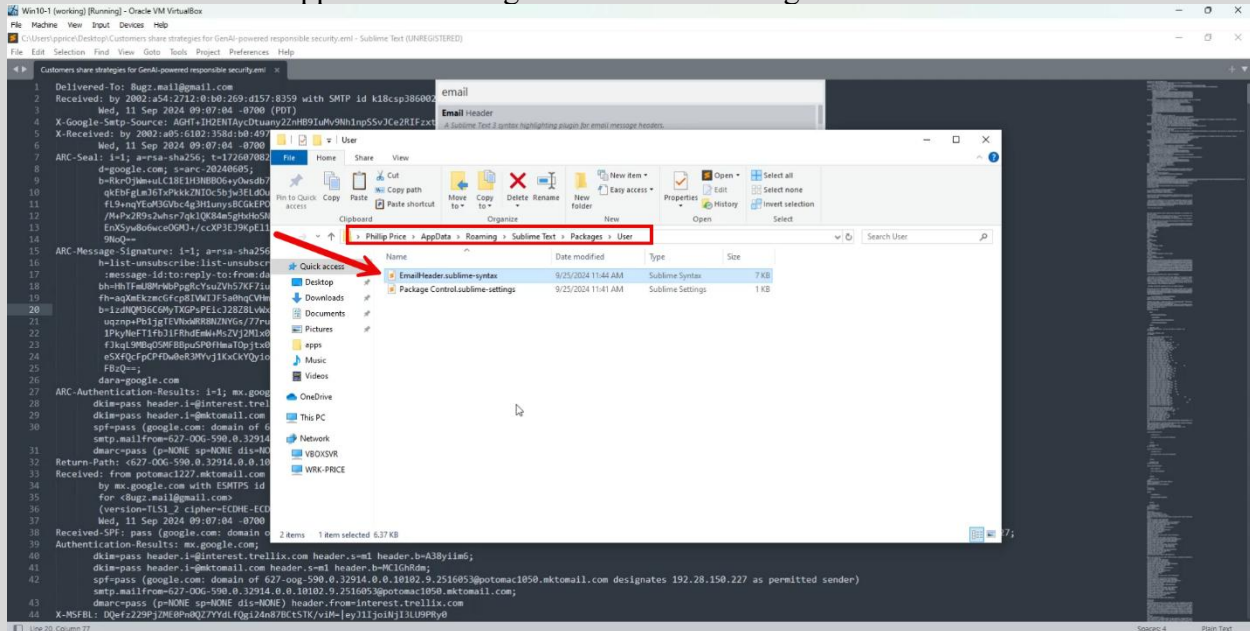
- Another input window will open; type in the email, and you will see the Email Header.



- Select the link to the GitHub page and download the latest release.



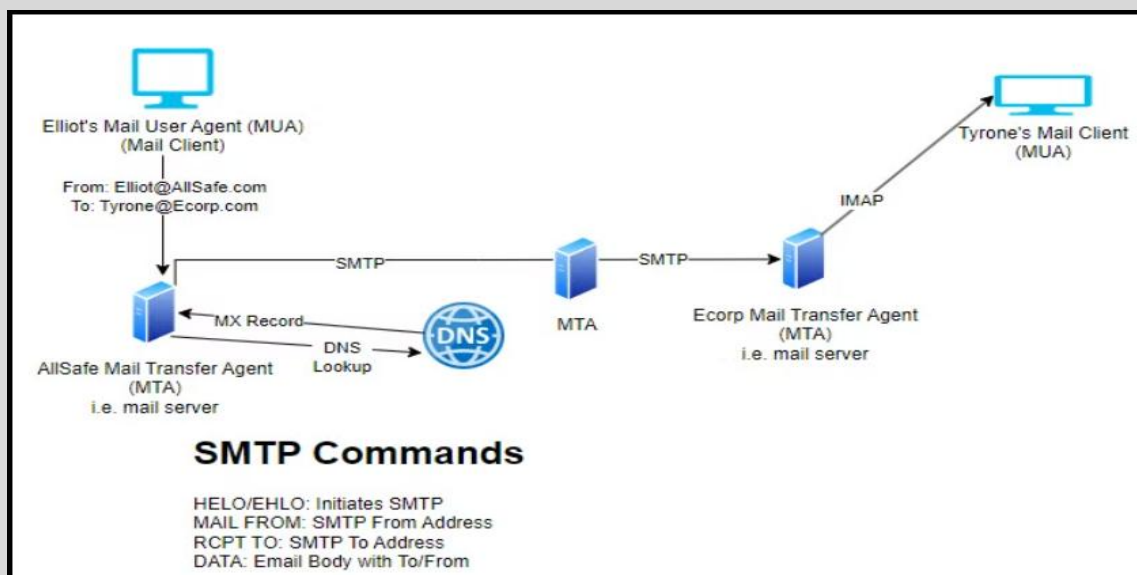
- Unzip the file, copy the EmailHeader.sublime-syntax file, and paste it in the <Username>\AppData\Roaming\Sublime Text\Packages\User folder.



Close Sublime Text Editor and reopen it. Open an .eml file with Sublime and choose email in the bottom right corner. Now the email header is formatted in an easy to read format.

How Email Works

The Email Delivery Process



Here's a basic explanation of how email works:

1. **Sending an Email:** When you compose an email, you typically use an email client or a web-based email service like Gmail, Yahoo Mail, or Outlook. In the email client, you provide the recipient's email address, subject, and the content of the message.
2. **Message Formatting:** The email client or service formats your message according to the standards set by the Internet Engineering Task Force (IETF), primarily using the Simple Mail Transfer Protocol (SMTP) for sending emails.
3. **SMTP Servers:** Once you hit "send," your email client connects to an SMTP server (Simple Mail Transfer Protocol server). This server is responsible for sending your email over the internet. You might have configured your email client to use a specific SMTP server provided by your email service provider.
4. **DNS Lookup:** Before the email is sent, the SMTP server performs a Domain Name System (DNS) lookup to find the Mail Exchange (MX) record for the recipient's domain. This record specifies the server responsible for receiving emails for that domain.
5. **Message Delivery:** After locating the recipient's email server, the SMTP server establishes a connection with it and sends the email. The recipient's email server receives the message and places it into the recipient's inbox or a designated folder.
6. **Recipient Retrieval:** The recipient can then retrieve the email by accessing their email account using an email client or web browser. They connect to their email server, typically using protocols like POP3 (Post Office Protocol version 3) or IMAP (Internet Message Access Protocol), authenticate themselves, and retrieve their messages.
 - **IMAP:** IMAP is designed for users who access their email from multiple devices or locations. When you use IMAP to retrieve your emails, the messages remain stored on the email server. It allows you to synchronize your email client with the server, so any changes you make to your emails (such as marking them as read, moving them to folders, or deleting them) are reflected across all your devices.
 - **POP3:** POP3, on the other hand, is more suitable for users who typically access their email from a single device or location. When you use POP3 to retrieve your emails, they are downloaded from the server to your device, and typically, they're removed from the server (though this behavior can be configured). Once downloaded, the emails are usually only accessible on the device where they were retrieved.
7. **Reading the Email:** Once the email is retrieved, the recipient can read it, reply to it, forward it, or take any other desired actions.
8. **Storage and Management:** Email servers store received messages until the recipient decides to delete them. Email clients also often store copies of messages locally on the recipient's device for offline access.
9. **Security Measures:** Throughout this process, various security measures are employed to protect the confidentiality and integrity of the email, such as encryption protocols (e.g., SSL/TLS) during transmission and spam filters to prevent unwanted messages from reaching the recipient's inbox.

This process ensures that emails are reliably delivered from sender to recipient across the internet, facilitating communication over vast distances almost instantly.

SMTP Fundamentals

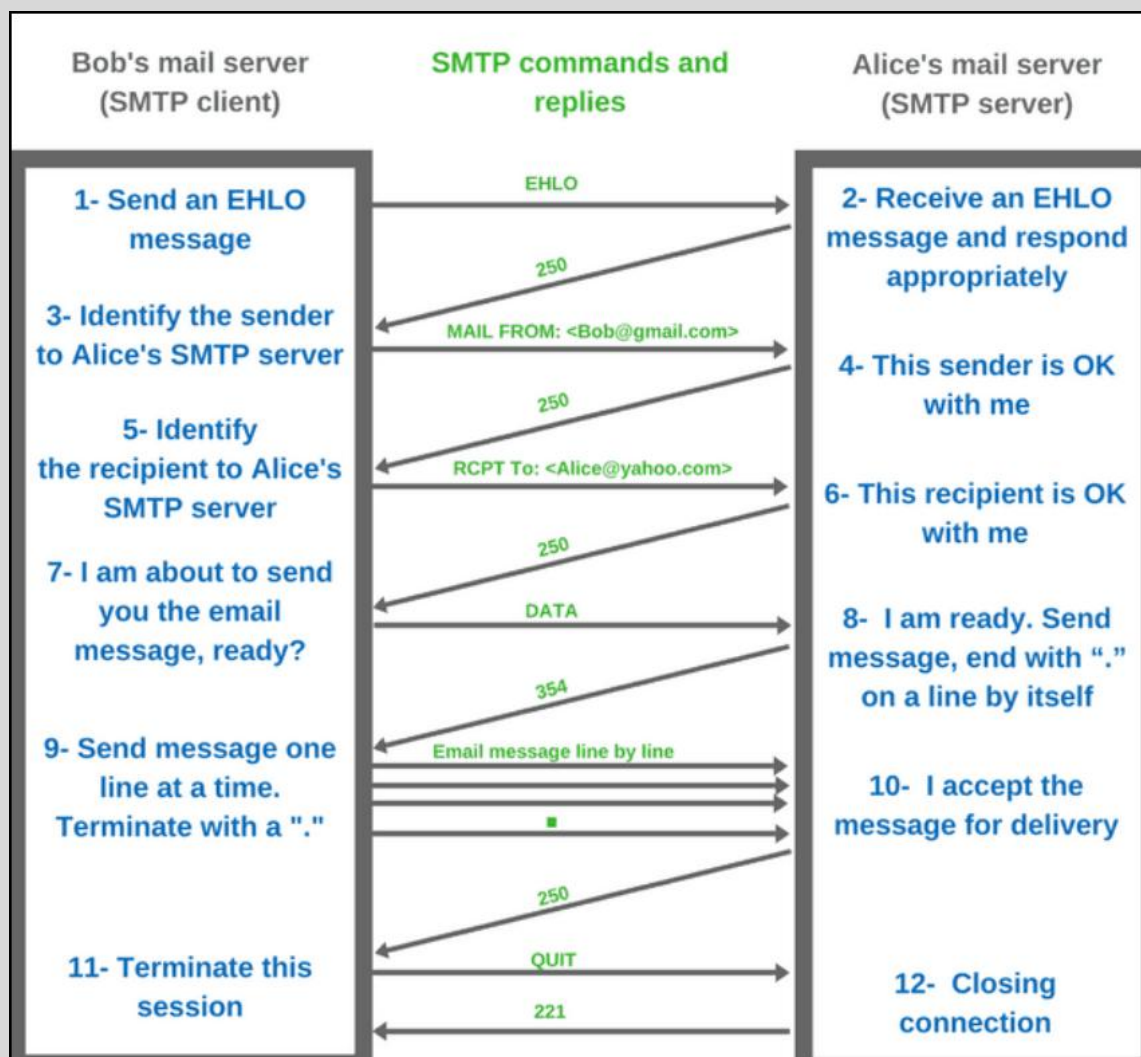
SMTP (Simple Mail Transfer Protocol) is the standard protocol for sending email across the internet. It operates as a "push" protocol, transferring messages from sender to recipient's mail server.

SMTP Operation Process

When a user sends an email, their email client (e.g., Outlook or Gmail) uses SMTP to relay the message to the sender's email server. The server then establishes a connection with the recipient's email server and forwards the message using a series of SMTP commands and responses.

Security and Vulnerabilities

A notable security limitation of SMTP is its lack of built-in encryption, which leaves email content susceptible to interception or tampering. However, this vulnerability can be mitigated by implementing additional security measures, such as Transport Layer Security (TLS), to protect communication.



Email Headers

Email header analysis is the process of examining the metadata contained in an email's header to determine its origin, trace its path through the mail servers, and identify potential red flags, such as phishing attempts or spoofed messages. **Email Header Example:**

```
Join George Kurtz for Hits and Highlights from Fal.Con 2024.eml
Delivered-To: t@gmail.com
Received: by 2002:a05:7208:421f:b0:89:fa62:60b2 with SMTP id u31csp2900750rbf;
  Tue, 24 Sep 2024 08:18:20 -0700 (PDT)
X-Google-Smtp-Source: AGHT+IF5Z4cu9VwcoLp5ioy9d/HCI9i5riuocwyhjNUVz/zLEbM4L1dXiktvRk5+VGNmEUGsw5rJ
X-Received: by 2002:a05:6808:3008:b0:3e2:8cab:9e45 with SMTP id 5614622812f47-3e28cab9f0emr4818060b6e.7.1727191099993;
  Tue, 24 Sep 2024 08:18:19 -0700 (PDT)
ARC-Seal: i=1; a=rsa-sha256; t=1727191099; cv=none;
  d=google.com; s=arc-20240605;
  b=RQqT490Vj08yFDFBiuCnzX5c8PutUrV7vKHwAgb5ah8BDweFPp1u6Fd8E+EAke/t+c
  m11/XBjpaA01bpIjQ6D84IhvPz07URZ29G19WInaLH/FXkRIzFSqQgBiUyVXRFjzVWTI
  63GkRMyf121sDj43RZ1bdD3kwFtr300s0gXoyrPHBVMoBxGShggtAITwN7t8Uqse2uP2
  J+Dh3YrSnoFxFKZeXzlgC0Ybw/T70VRM/wqxm4Kw6CXqIAJU/3AboLD0sZTCp5HB6ac
  Qf2N1LQksChER185BekAYsM0yUFh0kT6RfK04ZT1r69WL1IZ3Jzyy00PGHH1XjGqK51Z
  Auqw==
ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605;
  h=list-unsubscribe:list-unsubscribe-post:mime-version:subject
  :message-id:to:reply-to:from:date:dkim-signature:dkim-signature;
  bh=grzyggPoEFeQq8Gh09gMd9edWioChJwvi3WD4Jynys=;
  fh=q5GdHaoBOT/1X+UWIVNC013y+ovDIUx09gwcDKS5Ec=;
  b=Hg8xSz9vJui9E1SLAIHHzUqYxQsH/nf5eSg57Nyn5nM9H0MxHMuwnqT3XvZ7X2sKnI
  d2AoGlpCmMiuGa7HzKFytWfV6B/cG9RD9NCMsROfAbQxmhe3DK22dxUcvIgsJz+Me0g
  pOn6k2nH48TTMrGVdHdtqLj+K5avBIOFCRsN6kmKDtMFfA//IMvhTqQ/vOYzggCOW2zQ
  W76S2IuTXGOS4bY6np8y3onpbU+EkE+CD8NNIm1TdY4v8hpIzxBvZAHriB1jfsuTnM1m
  0SrPcgcb1lu6ShZRdv1Bw93wL60fuiozswFivLoXDPaBcF6Y428G1PPjPFxTcd/ANAm7
  859w==;
  dara=google.com
ARC-Authentication-Results: i=1; mx.google.com;
  dkim=pass header.i=@crowdstrike.com header.s=m2 header.b="pQBcJ/IF";
  dkim=pass header.i=@mktDNS.com header.s=m1 header.b=dXR1Iqf6;
  spf=pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates
  192.28.150.219 as permitted sender)
  smtp.mailfrom=281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com;
  dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=crowdstrike.com
Return-Path: <281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com>
Received: from marketing.crowdstrike.com (marketing.crowdstrike.com. [192.28.150.219])
  by mx.google.com with ESMTPS id ada2fe7eead31-4a1518b8f50s1541451137.710.2024.09.24.08.18.19
  for <@gmail.com>
  (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
  Tue, 24 Sep 2024 08:18:19 -0700 (PDT)
Received-SPF: pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates
  192.28.150.219 as permitted sender) client-ip=192.28.150.219;
Authentication-Results: mx.google.com;
  dkim=pass header.i=@crowdstrike.com header.s=m2 header.b="pQBcJ/IF";
  dkim=pass header.i=@mktDNS.com header.s=m1 header.b=dXR1Iqf6;
  spf=pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates
  192.28.150.219 as permitted sender)
  smtp.mailfrom=281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com;
  dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=crowdstrike.com
X-MSFBL: rym0+bQuJtLAixe3W3EwXOAtJi1lx+QI3FRAWojaV5IA=|eyJ1IjoIjMjglU9CUS0
  yNjY6MDoxNTMwODc6NjEzNDMyOjE2MzMyMjg6MTYyOTM3Ojk6NjA3NjMzOjMxNzg
  1NjY3IiwYiI6ImR2cC0xOTItMjgtMTUwLTIxOSIsImciOiIjZy1hYmQtNDczIiw
  icIiI6Im1pY2hhZWwuc3RlcjldHRAZ21haWwY29tIn0=
DKIM-Signature: v=1; a=rsa-sha256; q=dns/txt; c=relaxed/relaxed; t=1727191079;
  s=m2; d=crowdstrike.com; i=@crowdstrike.com;
  h=List-Unsubscribe:List-Unsubscribe-Post:Content-Type:MIME-Version:Subject:To:From:Date;
  bh=grzyggPoEFeQq8Gh09gMd9edWioChJwvi3WD4Jynys=;
  b=pQBcJ/IF5Bcm+7j12nX+aj5rV502YTV7R1wCG10uQuwcvVZlipoTaJ95ZfNa3tba
  VdaMm8ZFb/uoTabGUakoTa+iONHKmV7fBmOZT1YWA3pUXWTFGynjuXRTcdd3V1oHAYm
  QxtjLoheQ1unwhd+J5NAhe9fg3N+pwP8ng88oefXutT+RIu1TkGX9yXySMjkiKjuY5JN
  Su5S8Vcx8f+zVbAgDpJrz77yGjS5Zg87XBiy5n7pksvRyVZFN91jd/iu/tXTNjHv68F
  TnRn7wEPuNr2wpQAhVbyNQ2bFqdomAuV7YZgakBxL+7V3WwKyLobGby1esK1f4AwqGw
  x2zfNSMfBA==
DKIM-Signature: v=1; a=rsa-sha256; q=dns/txt; c=relaxed/relaxed; t=1727191079;
  s=m1; d=mktDNS.com; i=@mktDNS.com;
  h=List-Unsubscribe:List-Unsubscribe-Post:Content-Type:MIME-Version:Subject:To:From:Date;
  bh=grzyggPoEFeQq8Gh09gMd9edWioChJwvi3WD4Jynys=;
  b=dXR1Iqf6Ew5q1nXnYDskb8V0rAekoIsMgV+XELioha8GM6EBHkawRfuQT4L7kM
  AMSXxOygdZKB7cB0gk2B0qn8kCMLzWpW+iTqRtYrcadFxdqPojKCCrwm0MiKLuJcX
  bBrXIFQzIyPZdXdY5RzildI16Uus5Ia0qmHhHYWA=
Date: Tue, 24 Sep 2024 10:17:59 -0500 (CDT)
From: CrowdStrike <communications@crowdstrike.com>
Reply-To: communications@crowdstrike.com
To: @gmail.com
Message-ID: <131447797.706232022.1727191079289@abmktmail-batch1j.marketo.org>
Subject: Join George Kurtz for Hits and Highlights from Fal.Con 2024
```

Key Elements and Explanations

1. Delivered-To: ***@gmail.com**

This field shows the email address that the message was ultimately delivered to. It is useful in cases where emails are forwarded or if there are multiple recipients. In this case, it indicates the email was delivered to the Gmail account *****@gmail.com.

2. Received: by 2002:a05:7208:421f:b0:89:fa62:60b2 with SMTP id u31csp2900750rbf

The Received header shows the server that received the email and its corresponding IP or host (in this case, an IPv6 address 2002:a05:7208:421f:b0:89:fa62:60b2). Every time an email hops from one server to another, a new "Received" line is added, giving us a trace of the email's path. It also provides a timestamp (Tue, 24 Sep 2024 08:18:20 -0700 (PDT)), showing when the email was received by this specific server.

3. X-Google-Smtp-Source:

This field contains internal information used by Google to help identify the source of the email and track it through their systems. It's mainly useful for Google's internal processes and is not generally used for public analysis.

4. ARC-Seal and ARC-Message-Signature:

ARC (Authenticated Received Chain) headers are part of an authentication system. They allow intermediaries (like Google's servers) to pass along authentication results as the message moves through different mail systems. In this example, the signature (i=1) was successfully applied by google.com using rsa-sha256 encryption. It verifies that this email wasn't tampered with in transit between servers.

5. ARC-Authentication-Results:

This section shows the results of authentication checks performed by Google's email system:

- DKIM (DomainKeys Identified Mail) passed, meaning that the digital signature added by both crowdstrike.com and mktdns.com verified the email came from legitimate servers for those domains.
- SPF (Sender Policy Framework) passed, confirming that the IP address 192.28.150.219 is authorized to send emails on behalf of crowdstrike.com.
- DMARC (Domain-based Message Authentication, Reporting & Conformance) also passed. This verifies that both SPF and DKIM checks align with the domain in the "From" header.

6. Return-Path: 281-OBQ-

266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com

The return path is used to handle bounces (undeliverable emails). It shows the sender's email address used for bounce messages, which, in this case, is a marketing email from crowdstrike.com.

7. Received: from marketing.crowdstrike.com (192.28.150.219)

This line shows that the email was received from a server at marketing.crowdstrike.com with IP address 192.28.150.219. It adds credibility that this is indeed from CrowdStrike because the IP address resolves to their infrastructure.

8. Received-SPF: pass

The SPF check passed, meaning Google's server verified that the email came from an authorized server. This prevents email spoofing by verifying the sender's IP.

9. DKIM-Signature:

DKIM provides a method for validating that the message wasn't altered during transit and that it truly came from the claimed domain. The m2 selector was used for crowdstrike.com, and it passed the verification process.

10. Date: Tue, 24 Sep 2024 10:17:59 -0500 (CDT)

This field shows when the email was originally sent. It helps us verify the message's timeline and its alignment with the times in the "Received" headers.

11. From: CrowdStrike communications@crowdstrike.com

The sender is listed as communications@crowdstrike.com, which matches the authenticated domain seen in earlier headers (SPF and DKIM passed for this domain). This is a marketing communication from CrowdStrike.

12. To: ***@gmail.com**

This shows the recipient's address again, confirming that the email was intended for *****@gmail.com.

13. Message-ID: 131447797.706232022.1727191079289@abmktmail-batch1j.marketo.org

Every email has a unique message ID, which helps to identify it in mail systems. This is useful for tracking specific emails across different systems.

14. Subject: Join George Kurtz for Hits and Highlights from Fal.Con 2024

This is the subject line that appears in the recipient's inbox. While it's not directly tied to security analysis, it provides context to the content of the email.

What to Learn from this Legitimate Email Header

Consistency Across Fields: A legitimate email will have consistent information across all headers. In this case:

- The *From*, *Return-Path*, and *Received* headers all indicate that the email was sent from crowdstrike.com.
- The SPF, DKIM, and DMARC checks all pass, further proving the email's authenticity.

DKIM Signature and SPF Checks: These are essential to verify the legitimacy of the email. The passing status of both means the email was authorized by *crowdstrike.com* and wasn't altered in transit.

Received Headers Trace the Email's Journey: An important part of email header analysis is checking the chain of *Received* headers. A legitimate email should show a clear, logical path through authorized mail servers to the recipient's server.

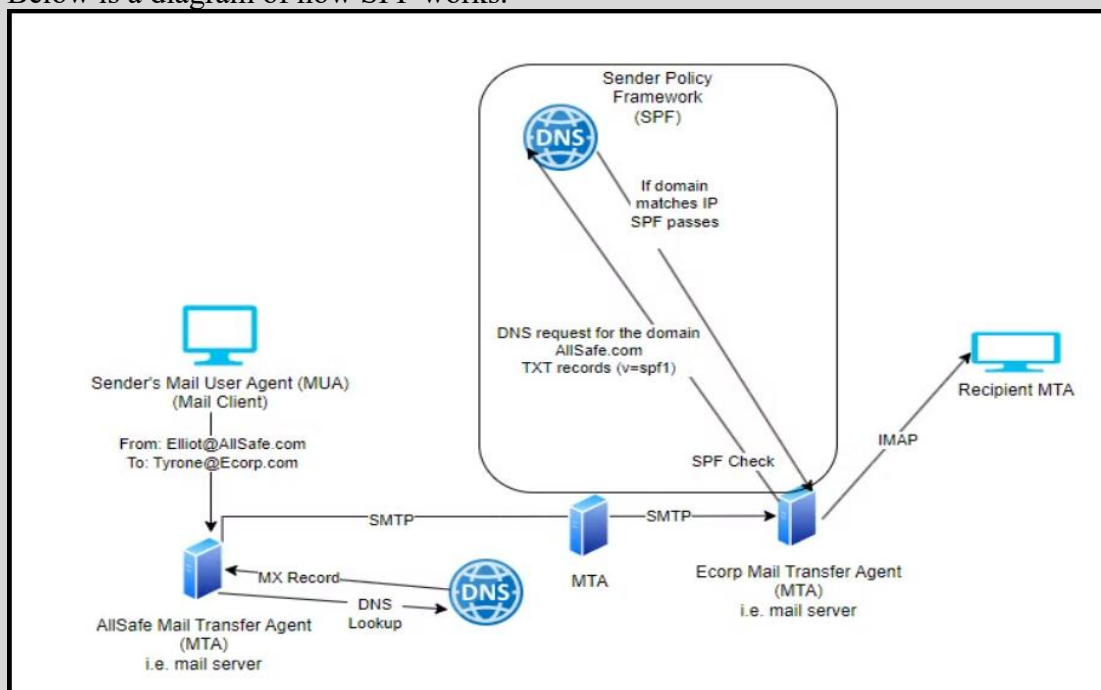
By understanding these key fields and learning how to interpret them, cybersecurity analysts can confidently analyze email headers and differentiate between legitimate and malicious emails.

Email Authentication

SPF (Sender Policy Framework): *spf=pass* confirms that the sending server (192.28.150.219) is authorized to send email on behalf of *crowdstrike.com*.

Sender Policy Framework (SPF) is often denoted in the header with a "Received-SPF" line. It helps authenticate the origin of the message. SPF allows organizations to identify which mail servers are allowed to send email from their domain. It provides an easy means for receiving mail transfer agents to validate the sending IP address to the purported domain. The primary purpose is to prevent spammers from forging messages from a specific domain. Not every mail server will include this information, but you should be suspicious of any failures noted in the email header.

Below is a diagram of how SPF works.



Basically, the receiving mail server performs a DNS query for the sending domain's TXT record. One of the lines starts with "v=spf1" and then lists IP addresses. If one of those IP addresses matches the sending IP address, the SPF passes.

To demonstrate how SPF works we can use nslookup to retrieve SPF Records.

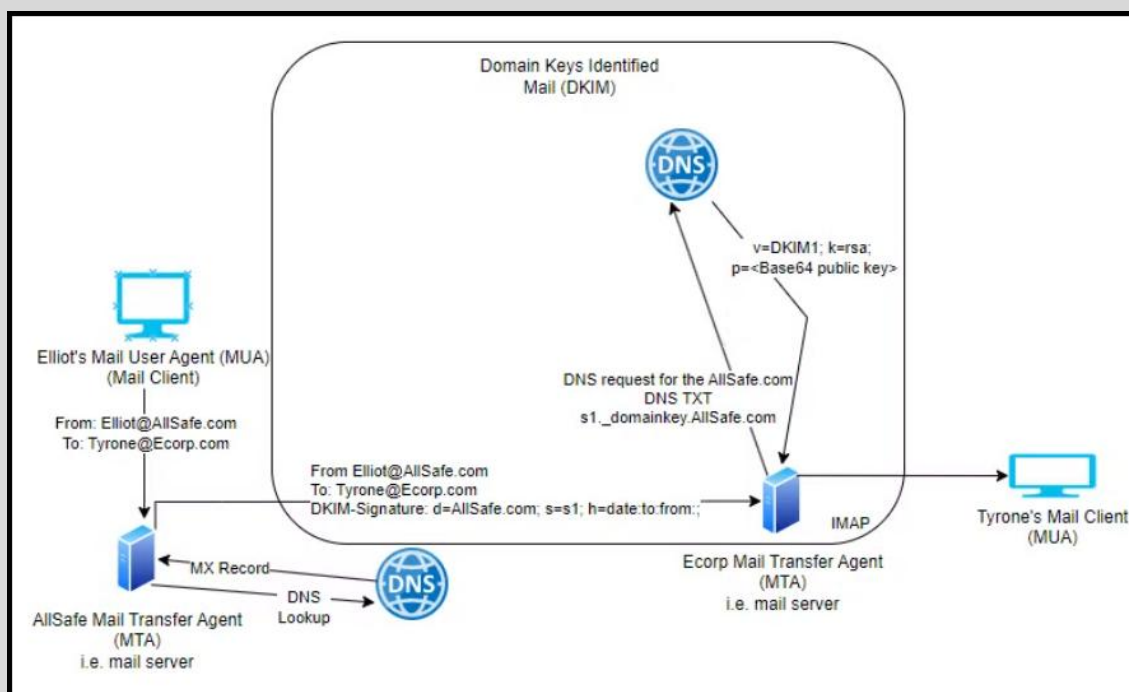
```
m122@DESKTOP-B1G1JM6:~$ nslookup -type=txt crowdstrike.com | grep -i spf
crowdstrike.com text = "v=spf1 mx include:mxtoemail.com include:amazonses.com include:spf-00206402.pphosted.c
om include:spf-00206401.pphosted.com include:_spf.salesforce.com include:servers.mcsv.net a:spf.servicenowse
rvices.com ip4:208.42.226.9/32 ip4:208.42.226.8/32 ip4:50.112.1" "31.18/32 ip4:54.191.184.169/32 ip4:50.112.
181.63/32 ip4:148.163.152.21/32 ip4:148.163.148.21/32 ip4:64.79.155.0/24 ip4:207.218.90.0/24 ip4:192.254.118
.63 ip4:54.240.34.17 ip4:54.240.34.18 ip4:54.240.34.19 ip4:54.240.34.204 ip4:54.240.34.205 ip4:54.240.34." "
206 ip4:54.240.34.207 ip4:54.240.59.90 ip4:54.240.59.92 ip4:54.240.59.93 ip4:35.171.200.76 ip4:54.183.25.1 i
p4:52.52.102.47 ip4:192.174.90.242 ip4:52.8.44.174 ip4:139.60.152.0/22 ip4:64.69.212.0/24 ip4:162.247.216.0/
22 ip4:52.26.233.205/32 ip4:44.236.4.51" "/32 ip4:208.42.231.60/32 ip4:54.240.59.91 ~all"
m122@DESKTOP-B1G1JM6:~$
```

As seen above, we can see the IP addresses that are authorized to send emails for CrowdStrike.

We also see that [spf.salesforce.com](#) and [spf.servicenowservices.com](#) are authorized. That means that the IP addresses from those domains are also authorized to send emails for [crowdstrike.com](#).

DKIM (DomainKeys Identified Mail): *dkim=pass* shows that the DKIM signature was verified and that the message has not been altered.

DomainKeys Identified Mail (DKIM) information is another mechanism to validate the source and content of a message by allowing the originating server to sign the message with a private key digital signature. DKIM can be used to protect the entire message, or just parts like the "From:" field. A valid DKIM check authenticates the sending domain with the public key and ensures elements of the message were not changed en route from the original mail server.



We can demonstrate this from our terminal.

```
m122@DESKTOP-B1G1JM6:~$ nslookup -type=txt m2._domainkey.crowdstrike.com
Server:      10.255.255.254
Address:     10.255.255.254#53

Non-authoritative answer:
m2._domainkey.crowdstrike.com text = "v=DKIM1;k=rsa;p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAtaGISaB1
f0TmEqvD65Ny2wBEJtTnJ/NM6b5vEnv3aqi/J/fak4cJQazl8PkoF4H4prm/hL/F304n9dh8x3MbSXaNXcu6icKhmw7S/BJLGX06R2NiSFMD
kzBBj3SLMGclwi4XZkEPmsZa49M5xfPMxth9fKfgMN17p6OUivYjYGgnwrkX2pUGTLVN8do6TBCm2jo" "qv0/est1PSOP5WQo2JZ3DoJaxM
J46U2mLC016nG5zvDnEfcSdhe/B0Wf7r/LmUJ0j97aSK3FwisQ20raodxNJH4UtnxqkMemgsZoZU7Eh7iq26o0mthD0q416A1KKdye0rJ6zd
REA27ADqnVsCQIDAQAB"
```

DMARC (Domain-based Message Authentication): *dmarc=pass* confirms that both SPF and DKIM passed, ensuring the email is from the legitimate domain (*ecorp.com*). Allows domain owners to establish how emails that fail SPF or DKIM are handled.

Bypassing Email Authentication

Attackers can find ways to bypass or manipulate email authentication systems, but these methods typically involve exploiting weak configurations, vulnerabilities, or user behavior. Here are some common tactics:

1. Domain Spoofing with Misconfigured SPF or DKIM

Attackers can exploit weak or incomplete SPF and DKIM configurations. If the domain hasn't set up SPF or DKIM properly, it's easier to spoof that domain's email address, meaning attackers can send emails that look like they come from a trusted source.

Example: If a domain's SPF record is not strict, attackers may use a third-party server to send phishing emails that appear legitimate.

2. Lookalike Domains (Domain Impersonation)

Instead of spoofing, attackers might register a domain that looks very similar to a legitimate one. For instance, using "amaz0n.com" instead of "amazon.com."

Since the attacker owns this lookalike domain, they can easily pass SPF, DKIM, and DMARC checks because they control the email infrastructure of that domain. The email may seem authentic to the recipient.

3. Subdomain Spoofing

If the main domain has email authentication set up properly but subdomains do not, attackers can exploit this loophole to send emails from a subdomain that looks legitimate but isn't protected.

Example: An attacker might send emails from "offers.company.com" if only "company.com" has SPF and DKIM, while the subdomain doesn't.

4. Compromised Email Accounts

Instead of bypassing authentication systems, attackers can take over legitimate email accounts through phishing or weak credentials. Once inside, they don't need to worry about SPF, DKIM, or DMARC since emails will come from valid accounts.

Example: If an attacker compromises the CEO's email account, any emails they send will appear authentic because they're using the real account.

5. Exploiting Weak DMARC Policies

If a domain's DMARC policy is set to "none," it means that even if SPF or DKIM checks fail, no specific action will be taken (such as rejecting the email). Attackers can exploit this by sending emails that fail authentication but still reach the inbox.

Example: A company might publish a DMARC record but not enforce it, allowing attackers to send spoofed emails without consequence.

6. Third-Party Services Not Covered by SPF/DKIM

Organizations may use third-party services (like marketing or newsletter platforms) to send emails. If these services are not added to the SPF record or not properly configured with DKIM, attackers can impersonate these services.

Example: An attacker can send a phishing email pretending to be a marketing email from a third-party service used by the company, and it might not trigger any security flags.

7. Social Engineering

Even if email authentication is correctly set up, attackers can still craft emails that look convincing enough for users to fall for scams. They might create fake internal emails (e.g., a CFO sending a payment request) or impersonate trusted third parties to trick recipients into clicking malicious links.

Example: An attacker might send an email from "it.support@company.com" (using a lookalike domain), hoping recipients won't notice the slight change and click on a phishing link.

In summary, while email authentication mechanisms like SPF, DKIM, and DMARC are strong defenses, attackers can still get around them by exploiting configuration weaknesses, leveraging lookalike domains, or using compromised accounts. It's essential to combine email authentication with user training and other security measures to minimize the risk.

Phishing Email Header Example

```
Return-Path: <admin@sec-ecorp.com>
Received: from suspicious-mail.com (unknown [198.51.100.25])
    by mailserver.recipientdomain.com (Postfix) with ESMTP id XYZ123456789
    for <analyst@recipientdomain.com>; Thu, 25 Sep 2024 12:34:56 +0000 (UTC)
Received: from spoofed-server (localhost [127.0.0.1])
    by suspicious-mail.com (Postfix) with ESMTP id 456DEF12345
    for <analyst@recipientdomain.com>; Thu, 25 Sep 2024 12:34:30 +0000 (UTC)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=sec-ecorp.com;
    s=selector1; h=from:to:subject:date:message-id:mime-version:content-type;
    bh=ab12345ghijklmno=;
    b=abcdefghijklmnopqrstuvwxyz1234567890uvwx1234567890;
Authentication-Results: mailserver.recipientdomain.com;
    spf=fail (mailserver.recipientdomain.com: domain of sec-ecorp.com does not designa
    dkim=fail (signature did not verify); dmarc=fail (p=reject) header.from=sec-ecorp.
From: "ECorp Admin" <admin@ecorp.com>
To: <analyst@recipientdomain.com>
Subject: Urgent: Review Your Executive Account
Date: Thu, 25 Sep 2024 12:34:30 +0000
Message-ID: <20240925123430.456DEF12345@suspicious-mail.com>
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8
Content-Transfer-Encoding: 7bit
```

Key Elements and Explanations

1. Return-Path: admin@sec-ecorp.com

Explanation: The *Return-Path* address is the email address where any bounced messages (e.g., non-deliverable emails) would be returned. While this field looks somewhat legitimate (*admin@sec-ecorp.com*), it includes a subtle variation (*sec-ecorp.com*) of the real domain (*ecorp.com*). This is a common tactic used in phishing attacks to trick users who don't closely inspect the email address.

Red Flag: The slight alteration in the domain name (*sec-ecorp.com*) indicates a likely phishing attempt, as the real email domain should be *ecorp.com*.

2. Received Headers:

These headers are crucial for tracing the journey of the email. Legitimate emails should have a clear and logical flow between mail servers. Here's what stands out in this phishing attempt:

```
Received: from suspicious-mail.com (unknown [198.51.100.25])  
by mailserver.recipientdomain.com (Postfix) with ESMTP id XYZ123456789  
for <analyst@recipientdomain.com>; Thu, 25 Sep 2024 12:34:56 +0000 (UTC)
```

Explanation: The email was received from *suspicious-mail.com*, which is a questionable domain. The IP address *198.51.100.25* does not belong to the legitimate *ecorp.com* mail server. The domain *suspicious-mail.com* is a strong indicator that the email originated from a non-trusted source.

Red Flag: The sending domain and IP address should be associated with *ecorp.com*, but in this case, they are not.

```
Received: from spoofed-server (localhost [127.0.0.1])  
by suspicious-mail.com (Postfix) with ESMTP id 456DEF12345  
for <analyst@recipientdomain.com>; Thu, 25 Sep 2024 12:34:30 +0000 (UTC)
```

Explanation: The second *Received* line shows the email was sent from a *localhost* address (*127.0.0.1*), which is highly suspicious. This means the email may have been generated locally on a compromised machine and relayed through *suspicious-mail.com*, which is not typical for legitimate emails.

Red Flag: Emails should not originate from *localhost* in a normal email flow, and this shows possible spoofing or server abuse.

3. DKIM-Signature:

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=sec-ecorp.com;  
s=selector1; h=from:to:subject:date:message-id:mime-version:content-type;  
bh=ab12345ghijklmno=;  
b=abcdefghijklmnpqrst1234567890uvwxyz1234567890;
```

Explanation: The **DKIM-Signature** provides cryptographic proof that an email was not altered in transit. Here, the domain in the DKIM signature is *sec-ecorp.com* instead of the legitimate *ecorp.com*. The DKIM signature would be used to verify the email, but in this case, the domain is incorrect.

Red Flag: The DKIM domain (*sec-ecorp.com*) does not match the real domain, indicating potential spoofing. Additionally, the DKIM check failed (as seen in the Authentication-Results), meaning the signature could not be verified.

4. Authentication-Results:

```
Authentication-Results: mailserver.recipientdomain.com;  
    spf=fail (mailserver.recipientdomain.com: domain of sec-ecorp.com does not designate  
    dkim=fail (signature did not verify); dmarc=fail (p=reject) header.from=sec-ecorp.com
```

Explanation: This field summarizes the results of SPF, DKIM, and DMARC checks:

- **SPF (Sender Policy Framework):** The SPF check fails because the IP address *198.51.100.25* is not authorized to send emails on behalf of *sec-ecorp.com*.
- **DKIM (DomainKeys Identified Mail):** The DKIM signature also fails verification, suggesting the email may have been tampered with or is not legitimate.
- **DMARC (Domain-based Message Authentication):** The DMARC check fails, meaning both SPF and DKIM failed, and the email should be rejected based on the domain's policy.

Red Flag: All email authentication mechanisms (SPF, DKIM, and DMARC) fail, indicating the email is fraudulent and likely spoofed.

5. From: "ECorp Admin" admin@ecorp.com

Explanation: The "From" field displays *admin@ecorp.com*, but this is a spoofed address. Attackers often spoof the "From" field to make the email appear as if it came from a trusted source. However, based on the earlier headers (SPF and DKIM failures), this "From" field is not legitimate.

Red Flag: While the "From" field looks like a legitimate *ecorp.com* address, the underlying email infrastructure (shown in the Received headers) reveals that the email didn't originate from *ecorp.com*.

6. To: analyst@recipientdomain.com

Explanation: This field correctly shows the email addressed to the intended recipient. This field doesn't reveal any phishing intent but should be checked in conjunction with other fields.

7. Subject: *Urgent: Review Your Executive Account*

Explanation: The subject uses urgency to encourage the recipient to take immediate action, which is a common tactic in phishing emails. Phrases like "Urgent" and "Executive Account" are meant to draw the recipient's attention and prompt them to click without thinking critically.

Red Flag: The use of urgency combined with the suspicious technical details (SPF, DKIM failures) is a sign of phishing.

8. Message-ID: 20240925123430.456DEF12345@suspicious-mail.com

Explanation: The **Message-ID** is unique to the email and should generally match the domain of the sending server. In this case, it's from *suspicious-mail.com*, which does not match *ecorp.com*, further suggesting that this email is not from a legitimate source.

Red Flag: The mismatch between the "From" field and the domain in the Message-ID is another indicator of a phishing attempt.

Online Email Header Analyzers

MX Toolbox (<https://mxtoolbox.com/EmailHeaders.aspx>)

Header Analyzed

Email Subject: Join George Kurtz for Hits and Highlights from Fal Con 2024

Copy/Paste Warning

Copy/Pasting a header works for most people, but sometimes it can cause problems with things like DKIM Validation. For the best results, use our Email Deliverability tool

Delivery Information

DMARC Compliant

SPF Alignment

SPF Authenticated

DKIM Alignment

DKIM Authenticated

Relay Information

Received Delay:

1 seconds

From marketing.crowdstrike.com to mx.google.com

0 0.5 1 1.5 2 2.5

Relay (Seconds)

Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	marketing.crowdstrike.com 192.28.150.219	mx.google.com	ESMTPS	9/24/2024 3:18:19 PM	
2	1 Second		2092.a05.7208.4211b0.89f62.60b2	SMTP	9/24/2024 3:18:20 PM	

Headers Found

Header Name	Header Value
Delivered-To	h@gmail.com
X-Goog-Smtp-Source	AQHT+IF5ZdcuVwcolp5lov9dHCJ9r5kucwyhNlU7zLzE8MML1d0ktvRK5+VGNEnEU6aw5rJ
X-Received	by 2002.a05.6808.3008.b0.3a2.8cab.9e45 with SMTP id 5614622812147-3a2cab9f9e45d818060b6e 7 1727191099993; Tue, 24 Sep 2024 08:18:19 -0700 (PDT)
ARC-Seal	i=1; a=rsa-sha256; t=1727191099; c=none; d=google.com; s=sarc-20240605; b=RQqT49WVj6pJDFBliCzX5c8PutLV7wHwAg5ah8ED0veFPp1uF48E+FAkaH+c mJ10XBpAIOhplUqE0d4hVp0TURZZ9G9WlwaLHFXRlzfSqQ8luYHXRfjvWT1 63GRWlyf12JdQ43R21bdD3wFr 300sCpQyPbHBMbXGShgtA1TwN78UqezuP2 JdH3Yr5NofFK2eXtYCYbwT7OVRMwqm4Nk6CCKqAJU3AboLDosZtP5HBD6ac QZNLQKsChER858eAYsM0YUfh8kT6RKO4ZT1h69WUJZ3JzyOOPGh8QjGqK5Z Aug==
ARC-Message-Signature	i=1; a=rsa-sha256; c=relaxedrelaxed; d=google.com; s=sarc-20240605; b=List-Unsubscribe-List-Subscribe-Post-Mime-Version-Subject-Message-ID-to-reply-to-from-date-dkim-signature-dkim-signature-bb-grzyggPcEF+Qq8Gh9gMd9e4VioChJw3V0D4Jmys; b=q5G4H4eBOT7X+UWV NC013+revDluQxO8gwdK5eC; b=Hg8wSe5vJuSEISL8tUqYvQshHfSeSg57Nyn5nM9H0MhMuvngT3Wz7XzKt d2AoQpCmMuGa7hKfYhWV8BvG9RD9NCMsR0ABQpthe3DK22dUcVguz=MeQ pOn8k2H48T7MgVdHdtLjK5aBIOFCRA8N8mCDMFA/IMhTqQvO YzggCOW2Q W76S2JutXGOS4bY6npy3onpU+ELE+CD8WlmlTdy4v8pLzBVZ4H1BjfwTnM1m 0SpGcb1U6SHZd4vBw93wL60ulozwFvLxNDP4bFY 428GPPFPfXcdANn7 859w==; dara=google.com
ARC-Authentication-Results	i=1; mx.google.com; dkim=pass header=i@crowdstrike.com header=s=m2 header=b"pQBcJlF"; dkim=pass header=i@mktdns.com header=s=m1 header=b=dXR1lgf6; spf=pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates 192.28.150.219 as permitted sender) smtp.mailfrom=281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com; dmarc=pass (p=REJECT sp=REJECT dk=NONE) header=from-crowdstrike.com
Return-Path	<281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com>
Received-SPF	pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates 192.28.150.219 as permitted sender) client-ip=192.28.150.219;
Authentication-Results	mx.google.com; dkim=pass header=i@crowdstrike.com header=s=m2 header=b"pQBcJlF"; dkim=pass header=i@mktdns.com header=s=m1 header=b=dXR1lgf6; spf=pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates 192.28.150.219 as permitted sender) smtp.mailfrom=281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com; dmarc=pass (p=REJECT sp=REJECT dk=NONE) header=from-crowdstrike.com
X-MSFBL	rymOn8duLlAix3w3EwX0AUB+Ql3FR4WV5SIA+eyJ1p8MgJLUSCUSD yNYMdoxNTMwODcNEJnDMYQJ2ZMcMwJg6MTYyOTM3Oj6N6A3NMcQmKz 1NY3WwYl6ImR2C0bOTIMgMTUwLT8oTSlmdcOLJzy1hYmQmDcziw idl6Im1pY2VhZ3RlcuJd#RAZ21haWw uY299n0=
DKIM-Signature	v=1; a=rsa-sha256; q=dns/txt; c=relaxedrelaxed; t=1727191079; s=m2; d=crowdstrike.com; b=List-Unsubscribe-List-Subscribe-Post-Content-Type-MIME-Version-Subject-To-From-Date-bh-grzyggPcEF+Qq8Gh9gMd9e4VioChJw3V0D4Jmys; b=pQBcJlF5BCm +7JlDkx+8S1502YTY79hC08U2uvcvVZp0Ta39528h30a VidMmZf8u7o7AbGUaKaTa+QNH4mN76mOZT1YWA3pUXVTTgYhKARTcd5V1oH4Ym QxJl8heQumvhd+JnAhu9fg3N+pwP8g88oeDut1-Rlu1TKG3xyXySMJKuY5JN Su5o8Vc8f+ZvB4gDpJz7TyGSSZg67XBy5n7 pksRyVZ8N9gldutXTNJV58F 1nRn7wEPUh2upQ4hVvYNQ28fqpdmAuV7Y2gk8dL+7V3WwYl6ImR2C0bOTIMgMTUwLT8oTSlmdcOLJzy1hYmQmDcziw idl6Im1pY2VhZ3RlcuJd#RAZ21haWw uY299n0=
Date	Tue, 24 Sep 2024 10:17:59 -0500 (CDT)
From	CrowdStrike <communications@crowdstrike.com>
Reply-To	communications@crowdstrike.com
To	michael.sterrett@gmail.com
Message-ID	<131447797.766232022.17271910792819@abnktmail.batch1> marketo.org>
Subject	Join George Kurtz for Hits and Highlights from Fal Con 2024

Microsoft (<https://mha.azurewebsites.net/>)

Message Header Analyzer

Insert the message header you would like to analyze

Delivered-To: @gmail.com

Received: by 2002a05720842116089fa260b2 with SMTP id 31cqp2900750ab; Tue, 24 Sep 2024 08:18:20 -0700 (PDT)

X-Google-Smtp-Source: AGH7+P3Z4cu9Vwcolp5ov9d/HCI9S5uocuyh/NUvzLzE8M4L1d0k6Rk5+VGNmEU6v5fJ

X-Received: by 2002a0568083008b03e28cab9e45 with SMTP id 561462281247-3e28cab90em+4818060bde; Tue, 24 Sep 2024 08:18:19 -0700 (PDT)

ARC-Seal: i=1; a=rsa-sha256; t=1727181099; cv=none; d=google.com; s=arc-20240605; b=RQdT490V0b/FDFBuCnc3cEPuUv7XhWuqg5a8BDveffPp1u8fDE+Ekke+c m1/78paA0Cbpig6D84h+Pd0TURZ2909WnLH/FYXRfz5qQgbluYH0XfjvWTI 63GRWYf12uQ43R21bD3k6Fr300uQgkoyPhBVu8u6C0ggATuN7H8UapeuP2 j+Dn3Y5u5u6Fz2ZzgC0bW/TTCVRMwqem4Kw6CkqAUJ3AbolDOuZLp5H86ac QZNLQ4uChERf88u6uMQu6pK6N76RKC4ZT169WUJZ3ZyYQOPGh0t0yqK5Z Augw==

ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605;

Analyze headers

Clear

Copy

Submit feedback on github

received headers

Hop#	Submitting host	Receiving host	Time	Delay	Type
1	marketing.crowdstrike.com [192.28.150.219]	ms.google.com	9/24/2024 11:18:19 AM		ESMTPS
2		2002a05720842116089fa260b2	9/24/2024 11:18:20 AM	1 second	SMTP

Other headers

#	Header	Value
1	Delivered-To	@gmail.com
2	X-Google-Smtp-Source	AGH7+P3Z4cu9Vwcolp5ov9d/HCI9S5uocuyh/NUvzLzE8M4L1d0k6Rk5+VGNmEU6v5fJ
3	X-Received	by 2002a0568083008b03e28cab9e45 with SMTP id 561462281247-3e28cab90em+4818060bde; Tue, 24 Sep 2024 08:18:19 -0700 (PDT)
4	ARC-Seal	i=1; a=rsa-sha256; t=1727181099; cv=none; d=google.com; s=arc-20240605; b=RQdT490V0b/FDFBuCnc3cEPuUv7XhWuqg5a8BDveffPp1u8fDE+Ekke+c m1/78paA0Cbpig6D84h+Pd0TURZ2909WnLH/FYXRfz5qQgbluYH0XfjvWTI 63GRWYf12uQ43R21bD3k6Fr300uQgkoyPhBVu8u6C0ggATuN7H8UapeuP2 j+Dn3Y5u5u6Fz2ZzgC0bW/TTCVRMwqem4Kw6CkqAUJ3AbolDOuZLp5H86ac QZNLQ4uChERf88u6uMQu6pK6N76RKC4ZT169WUJZ3ZyYQOPGh0t0yqK5Z Augw==
5	ARC-Message-Signature	i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605; h=1; list-unsubscribe=unsubscribe-postmime-versions; subject: message-id=reply-to=from=datedkim-signature=dkim-signature: bh=grzyggP0EFeQg8Gh09yM8edWioChm3Wd4jmys; fh=q5dHAs80T7X+UWVhN013j+oDuQzO9gwdK5d c=; b=hg8bdc8u8E6L8AHzqzvcQmhm5e57Nn5m8m0MhmluamgT3KZ7X2kni dZAoQpCm8u6a7m07y8H8Ei09RD9HCmRC0AcCymh30K2ZbUvlgus+Me9y pQ8bZnH48TThMgV/Dht0qJ+K5vBfCfK3uNem4D8MFA/MAhTg2vC7zgCOW2zQ W765Du7XG054bHngby3ongpu+34e+CD8Wm1 16H4hp0uB24m8B96u7uM1m 05Rg0t4u0N28a4u8d84G0u0u0u7uL0d29a8eF94Z6SPPPh5dAlAnuT 838re=; d=arc-google.com
6	ARC-Authentication-Results	i=1; mx.google.com; dkim=pass header=i=@crowdstrike.com header=s=m2; header=bx: yQ8U/1F1; dkim=pass header=i=@mtdns.com header=s=m1; header=bx: 60811qR; spf=pass (google.com: domain of 281-obq-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com designates 192.28.150.219 as permitted sender) smtp=mailfrom=281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com; dmarc=pass (p=REJECT sp=REJECT dis=NONE) headerfrom=crowdstrike.com
7	Return-Path	<281-OBQ-266.0.607633.0.0.162937.9.31785667@marketing.crowdstrike.com>

General Email Analysis Tips

Identifying the Actual Sender: By examining the 'Received' lines, you can trace the email's path. The first 'Received' line at the top is the most recent server it passed through. If an email claims to be from a legitimate company but the path shows different servers, it might be suspicious.

Checking for Consistency: Verify if the 'Return-Path', 'Received', and 'From' fields are from the same domain. Discrepancies can indicate spoofing.

Analyzing Timestamps: Check the timestamps in the 'Received' lines. Unusual time delays or odd time zones could indicate a falsified email.

Verifying DKIM and SPF Records: These are email authentication methods. A failed DKIM (DomainKeys Identified Mail) or SPF (Sender Policy Framework) check could indicate that the email is not from the purported sender.

Tracing IP Addresses: 'Received' lines often include IP addresses of the mail servers. Use IP lookup tools to check the locations and authenticity of these servers.

Spotting Unusual Patterns: Look for patterns like strange formatting, unfamiliar server names, or other inconsistencies.

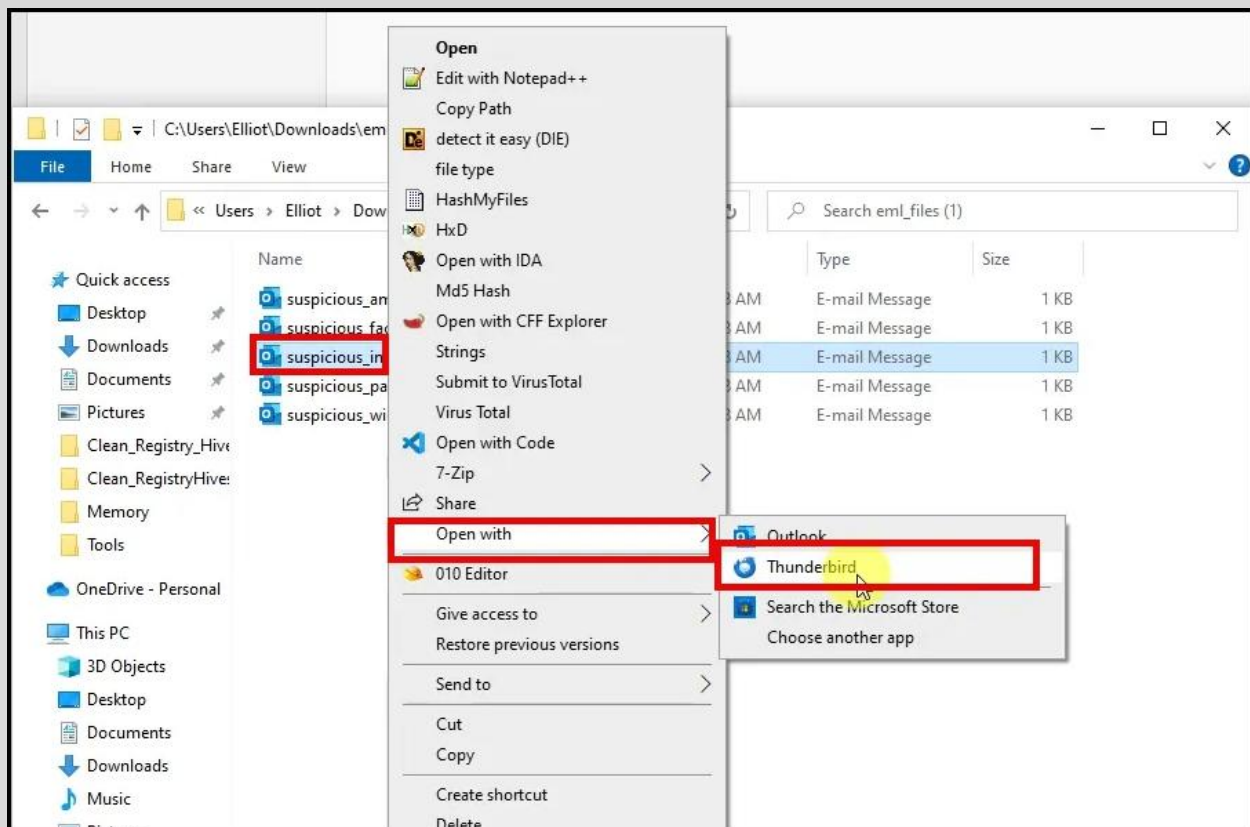
Caution with Links and Attachments: If the email contains links or attachments, be cautious. Analyze the URL by hovering over it without clicking, to see if it directs to a suspicious site.

Using Header Analysis Tools: There are various online tools available that can analyze email headers and highlight suspicious elements.

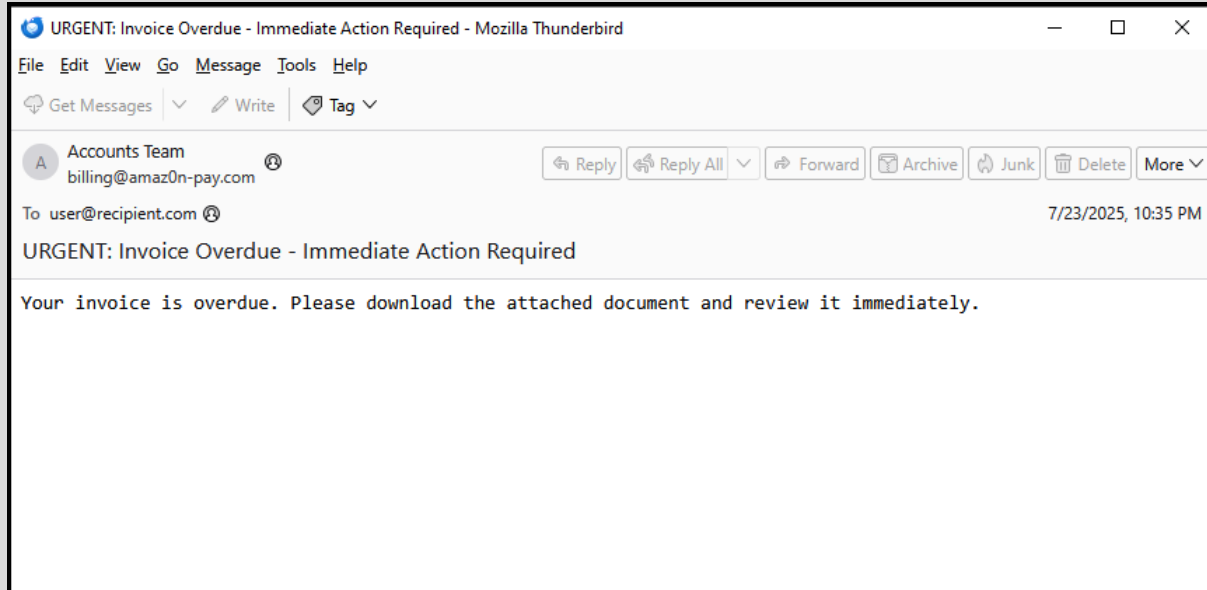
Practical Exercise

Download and analyze headers from the five .eml files linked below. Identify why each email header is suspicious, Link: [Eml_files.7z](#)

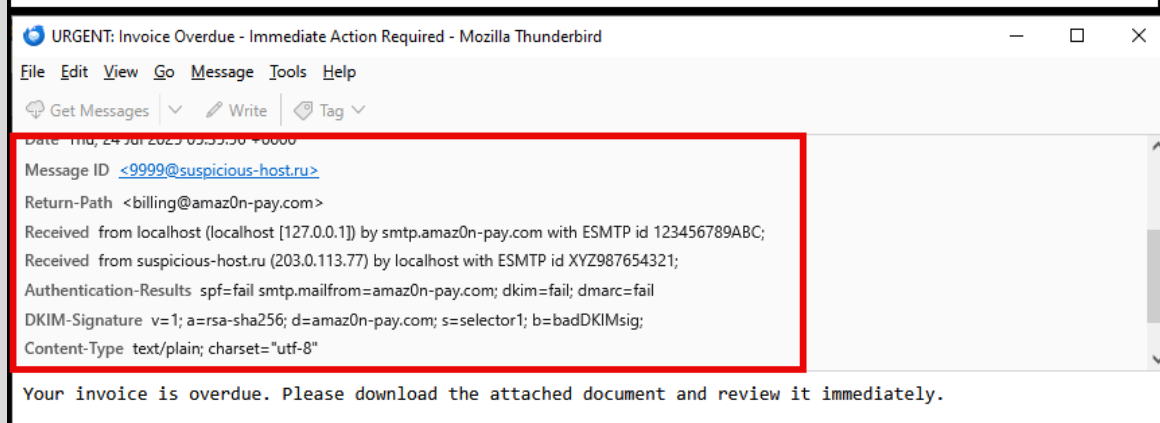
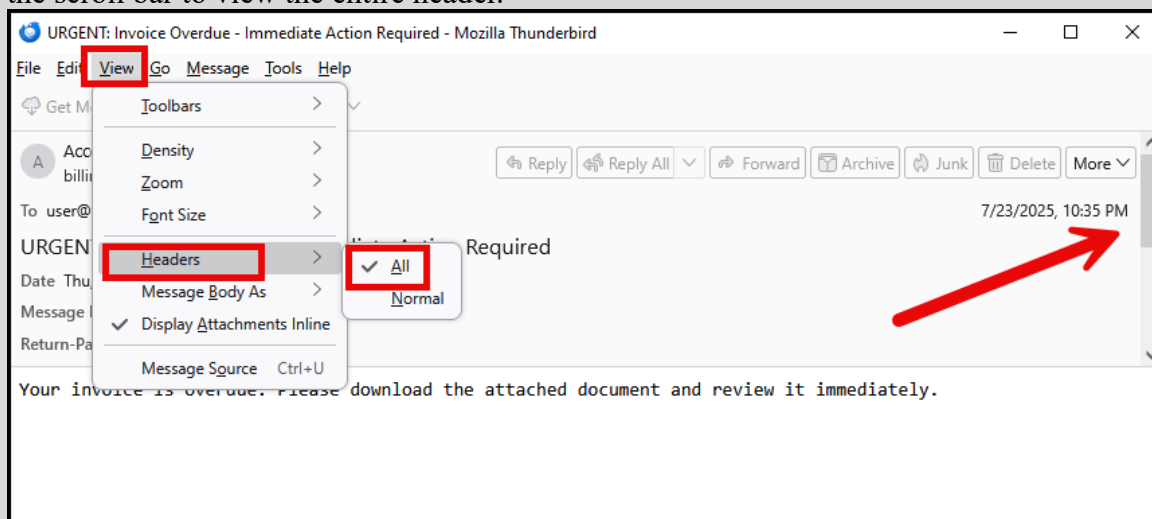
After downloading and unzipping the .eml files, open the first file in Thunderbird by right clicking the file and select “open with” Thunderbird.



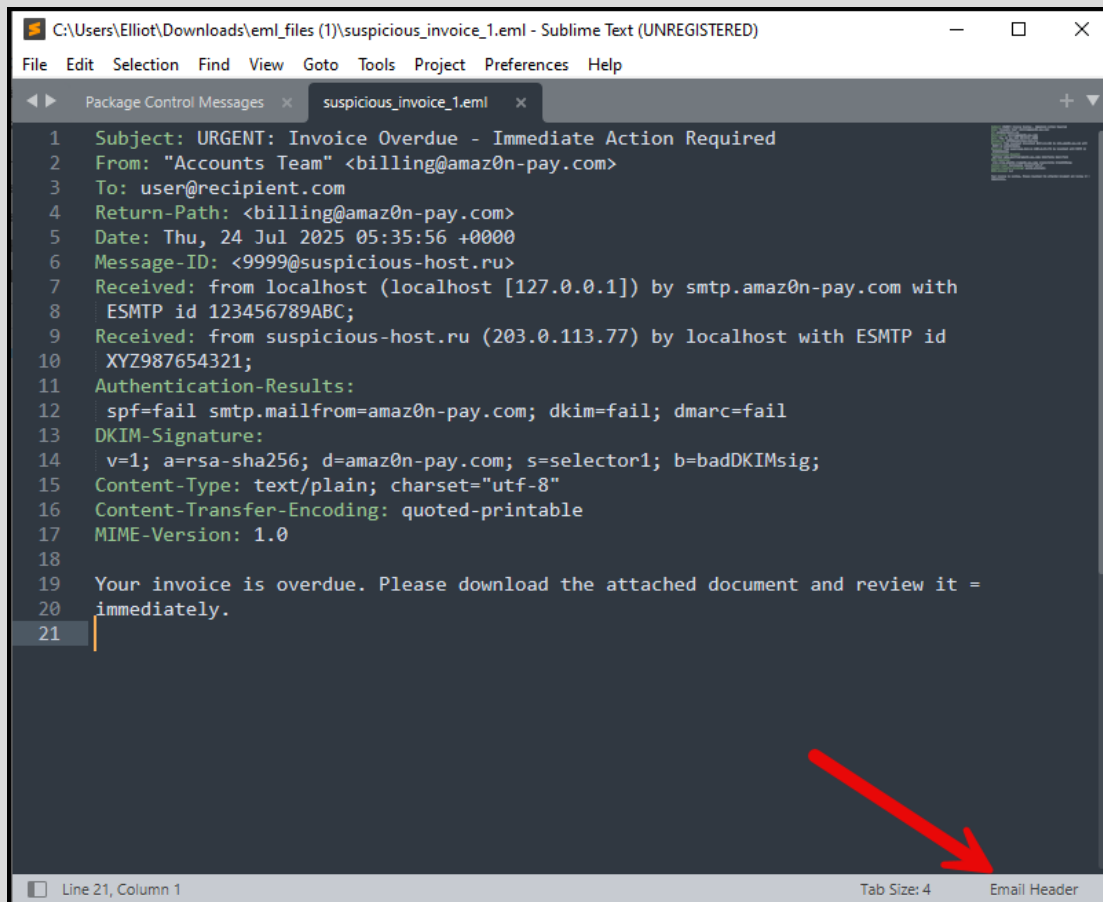
Review the email in Thunderbird and look for obvious anomalies.



Next, you can view the email header info by selecting View → Headers → All. Then you can use the scroll bar to view the entire header.



Alternatively, open the .eml file in Sublime text and choose the email header package on the bottom right.



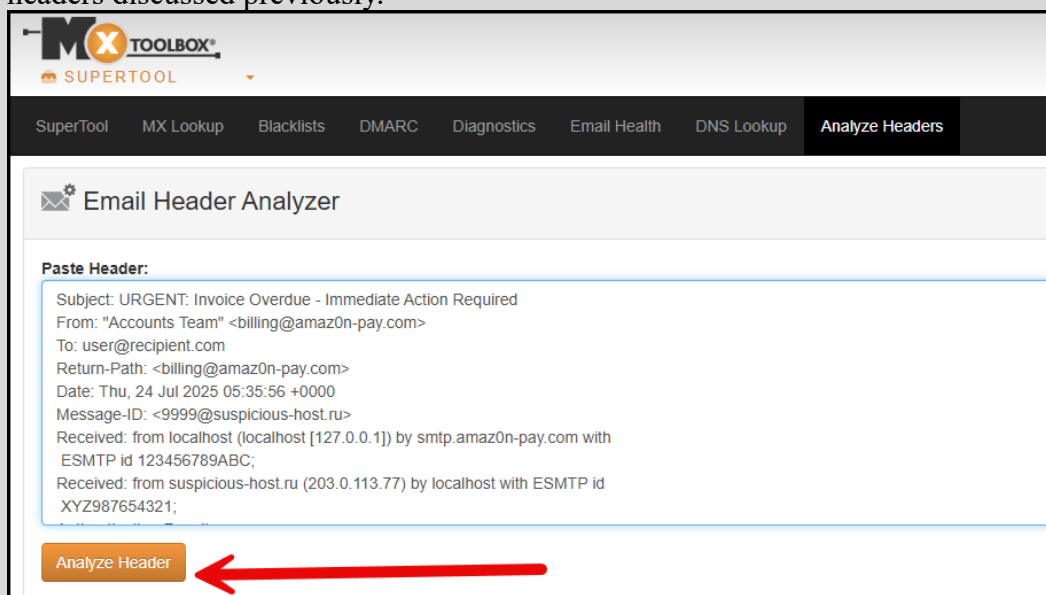
```
1 Subject: URGENT: Invoice Overdue - Immediate Action Required
2 From: "Accounts Team" <billing@amaz0n-pay.com>
3 To: user@recipient.com
4 Return-Path: <billing@amaz0n-pay.com>
5 Date: Thu, 24 Jul 2025 05:35:56 +0000
6 Message-ID: <9999@suspicious-host.ru>
7 Received: from localhost (localhost [127.0.0.1]) by smtp.amaz0n-pay.com with
8   ESMTP id 123456789ABC;
9 Received: from suspicious-host.ru (203.0.113.77) by localhost with ESMTP id
10   XYZ987654321;
11 Authentication-Results:
12   spf=fail smtp.mailfrom=amaz0n-pay.com; dkim=fail; dmarc=fail
13 DKIM-Signature:
14   v=1; a=rsa-sha256; d=amaz0n-pay.com; s=selector1; b=badDKIMsig;
15 Content-Type: text/plain; charset="utf-8"
16 Content-Transfer-Encoding: quoted-printable
17 MIME-Version: 1.0
18
19 Your invoice is overdue. Please download the attached document and review it =
20 immediately.
21
```

Line 21, Column 1

Tab Size: 4

Email Header

Lastly, you can also copy and paste the email header information to one of the on-line email headers discussed previously.



MX TOOLBOX
SUPERTOOL

SuperTool MX Lookup Blacklists DMARC Diagnostics Email Health DNS Lookup **Analyze Headers**

Email Header Analyzer

Paste Header:

Subject: URGENT: Invoice Overdue - Immediate Action Required
From: "Accounts Team" <billing@amaz0n-pay.com>
To: user@recipient.com
Return-Path: <billing@amaz0n-pay.com>
Date: Thu, 24 Jul 2025 05:35:56 +0000
Message-ID: <9999@suspicious-host.ru>
Received: from localhost (localhost [127.0.0.1]) by smtp.amaz0n-pay.com with
ESMTP id 123456789ABC;
Received: from suspicious-host.ru (203.0.113.77) by localhost with ESMTP id
XYZ987654321;

Analyze Header